



UnOAuthorized:

The previously untold findings



@ericonidentity.com



@ericonidentity



/in/ericonidentity



@ericonidentity@infosec.exchange



Eric Woodruff

Chief Identity Architect, Semperis





Background



Dirk-jan Mollema

Hacker, red teamer, researcher. Likes to write infosec-focussed Python tools. This is my personal blog containing research on topics I find interesting, such as (Azure) Active Directory internals, protocols and vulnerabilities.

Follow

Looking for a security test or training? Business contact via outsidersecurity.nl

Azure AD privilege escalation - Taking over default application permissions as Application Admin

🕒 5 minute read

During both my DEF CON and Troopers [talks](#) I mentioned a vulnerability that existed in Azure AD where an Application Admin or a compromised On-Premise Sync Account could escalate privileges by assigning credentials to applications. When revisiting this topic I found out the vulnerability was actually not fixed by Microsoft, and that there are still methods to escalate privileges using default Office 365 applications. In this blog I explain the why and how. The escalation is still possible since this behaviour is considered to be “by-design” and thus remains a risk.

In a previous blogpost, [I had detailed out the steps for automating permission grants](#) (for both delegated and application permissions) from a headless process, i.e. in automation, using a managed identity or service prinicipal. This is something you’d often use in DevOps.

There was a big downside in the approach I had outlined, it required you to grant AppRoleAssignment.ReadWrite.All to the automation account. To be fair, I did put a big warning there as follows.

controlled by assigning that work a lot with Azure application has been registered a service principal in a t

THREAT ANALYSIS

AZURE REDIRECT URI TAKEOVER VULNERABILITY

How to Backdoor Azure Applications and Abuse Service Principals

October 26, 2021

If an attacker gains access to an Azure tenant (with sufficient permissions) they can add a “secret” or allow an attacker single-factor access to Azure allowing the environment. Further, each application that exists within an Azure is automatically assigned/created. This happens every time an application registers a service principal account is basically an identity that’s used by the application to perform automated actions.

goals because:

- Service principals do not have MFA
- They can be created by a service principal account
- There are many applications in Azure (most companies have several)
- They can be accessed through conditional access

Goals, Applications, And

Assignment



← Back to blogs listing

Un0Authorized: Privilege Elevation Through Microsoft Applications

Identity Attack Catalog • Read 11 MIN

- Application integration
- Multitenant apps in Entra ID
- Multiple credentials
- Acting as Microsoft apps
- Elevating privileges through Microsoft apps
- Our findings



Eric Woodruff

Senior Security Researcher

This article details a series of [Semperis](#) security research team discoveries that resulted in the ability to perform actions in Entra ID beyond expected authorization controls, based on analysis of the OAuth 2.0 scope (permissions). Our most concerning discovery involved the ability to add and remove users from privileged roles, including the most powerful role in Entra ID: Global Administrator. We reported our findings to the Microsoft Security Response Center (MSRC), and we have worked with Microsoft to ensure that these discoveries have been resolved.

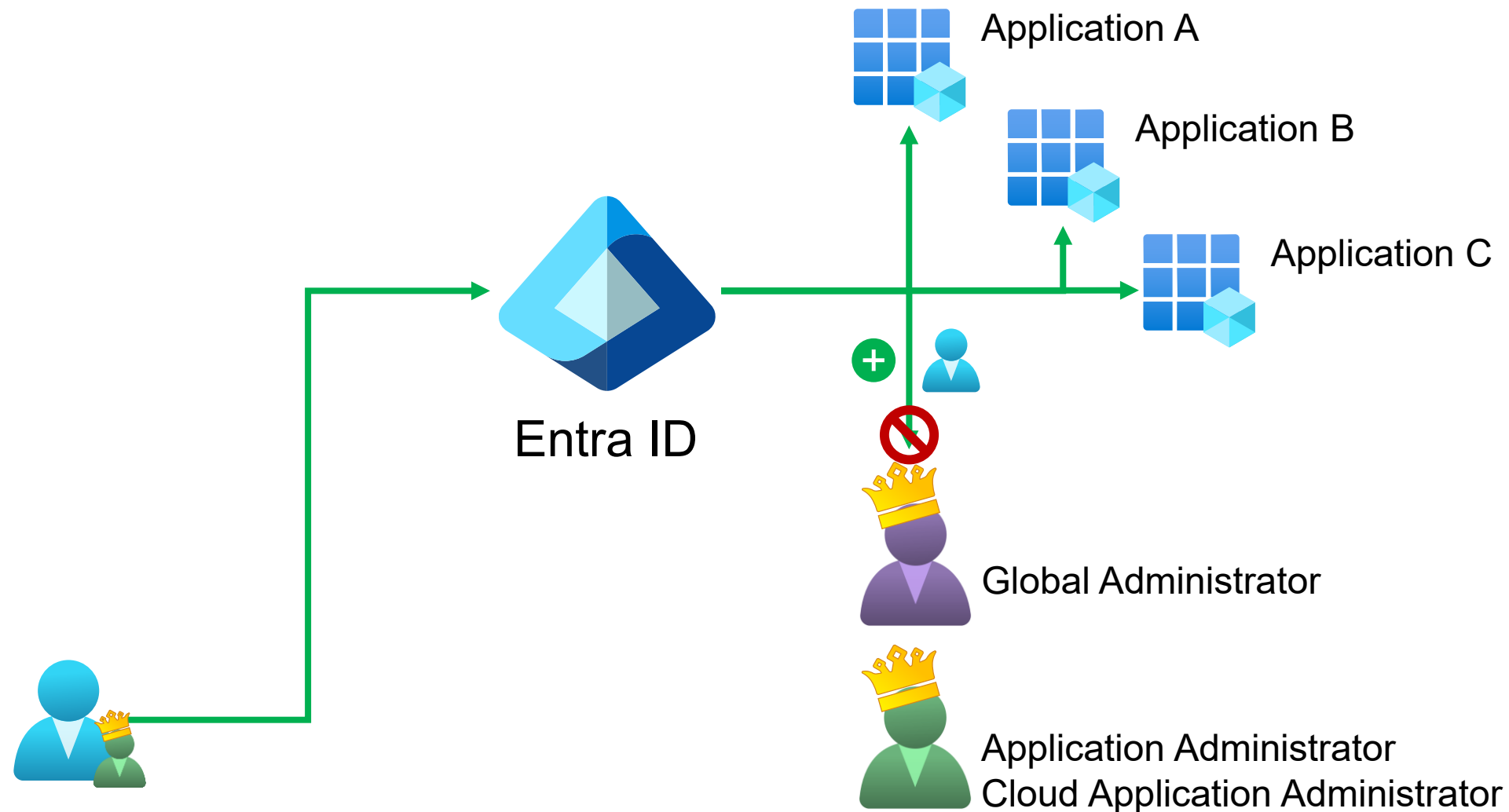
We will discuss how this functionality was uncovered, the mechanism behind it, and various attack paths to obtain family refresh tokens. We will demonstrate how this functionality can be abused to access sensitive data. Lastly, we will share relevant information to mitigate the theft of family refresh tokens.

Full details on UnOAuthorized

sl.entra.ms/unoauthorized

Application Administrator role
+
Specific Microsoft Multi-tenant applications
=
UnOAuthorized

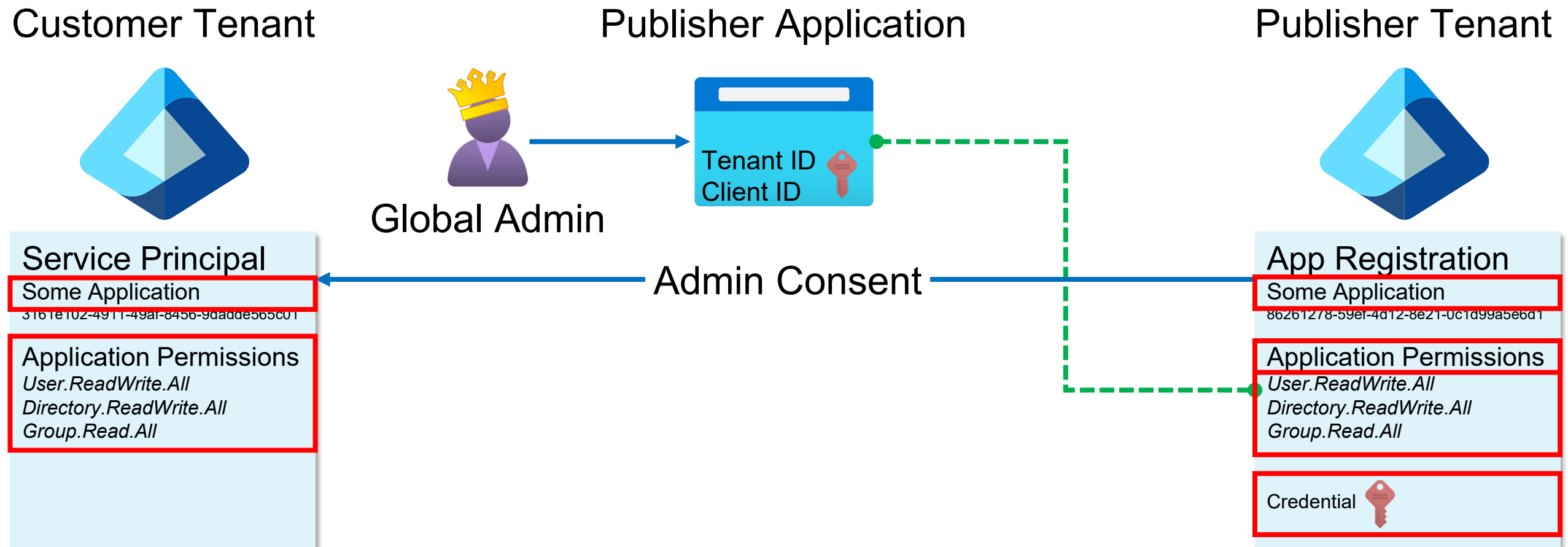
Application Administrator role



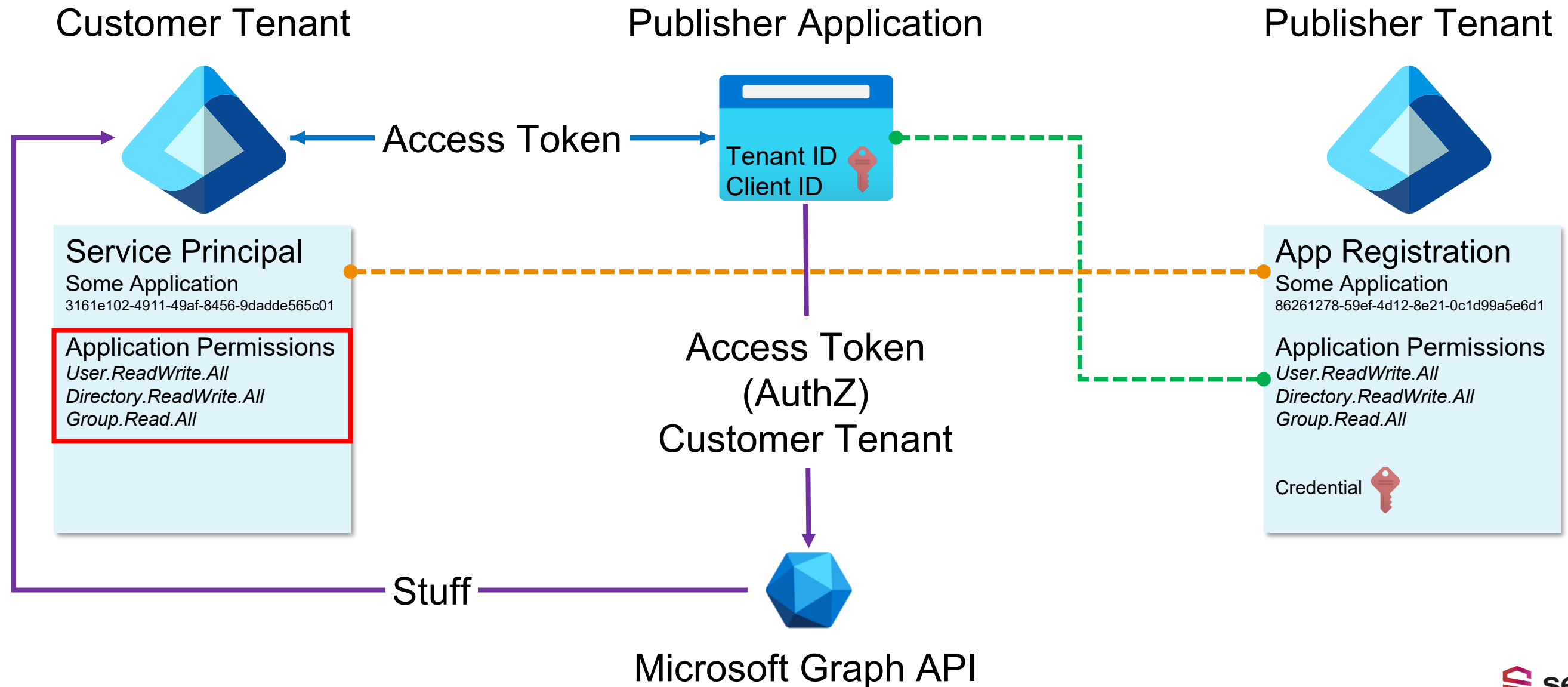


Multi-tenant applications

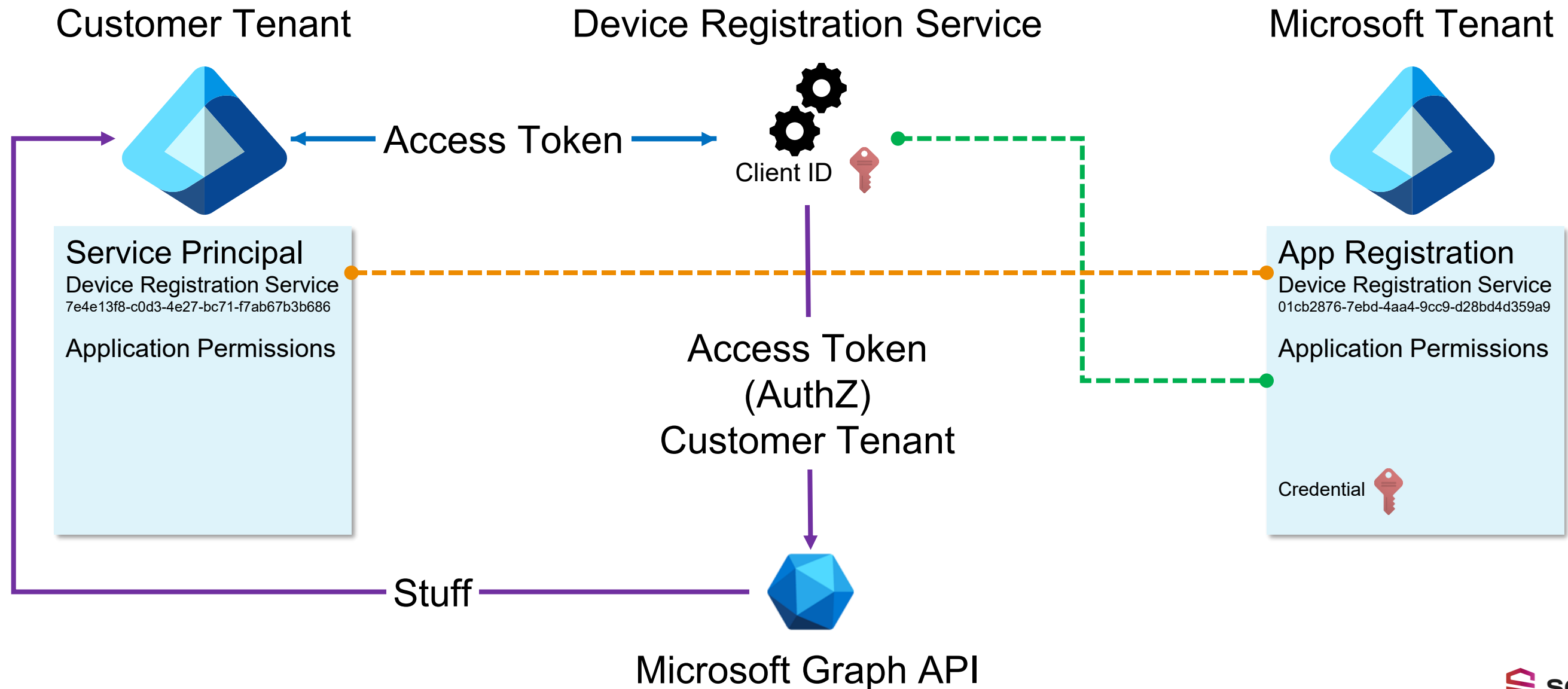
Multi-tenant applications



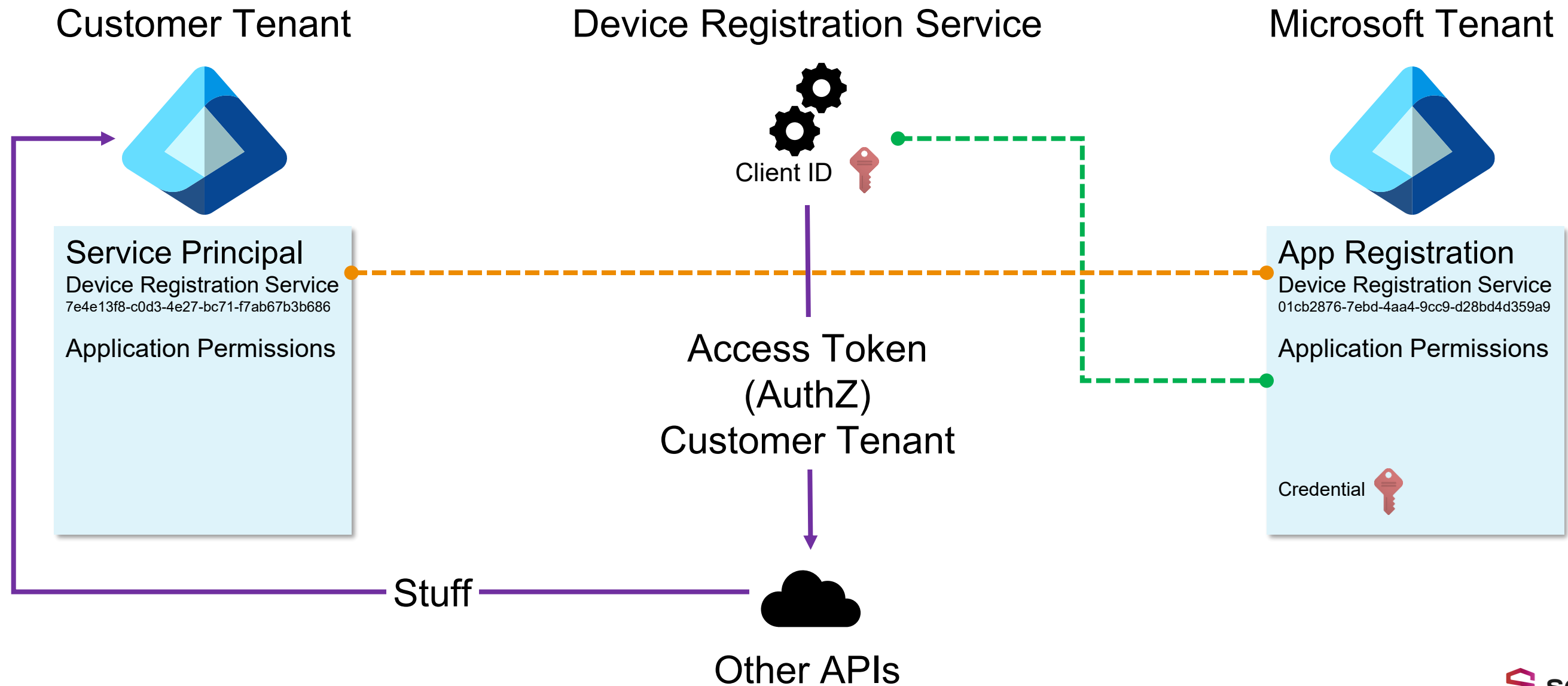
Multi-tenant applications



Microsoft applications



Microsoft applications



Impersonating Microsoft applications

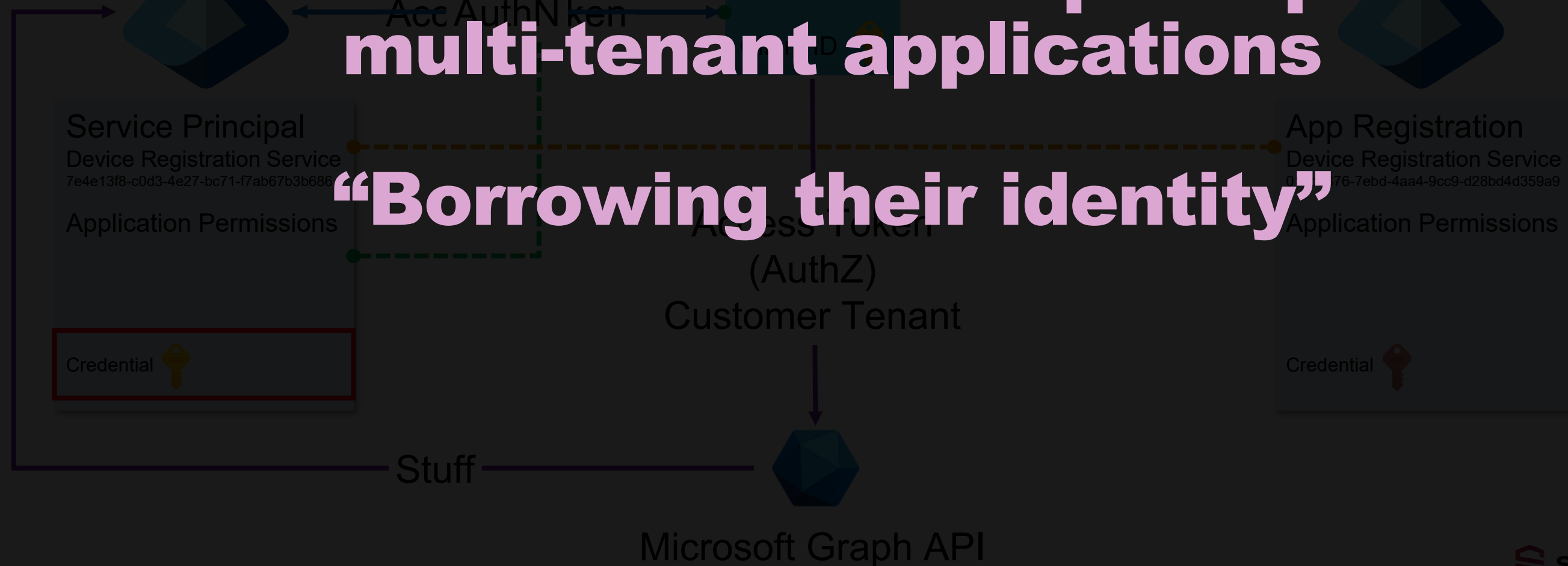
Customer Tenant

Impersonating Application

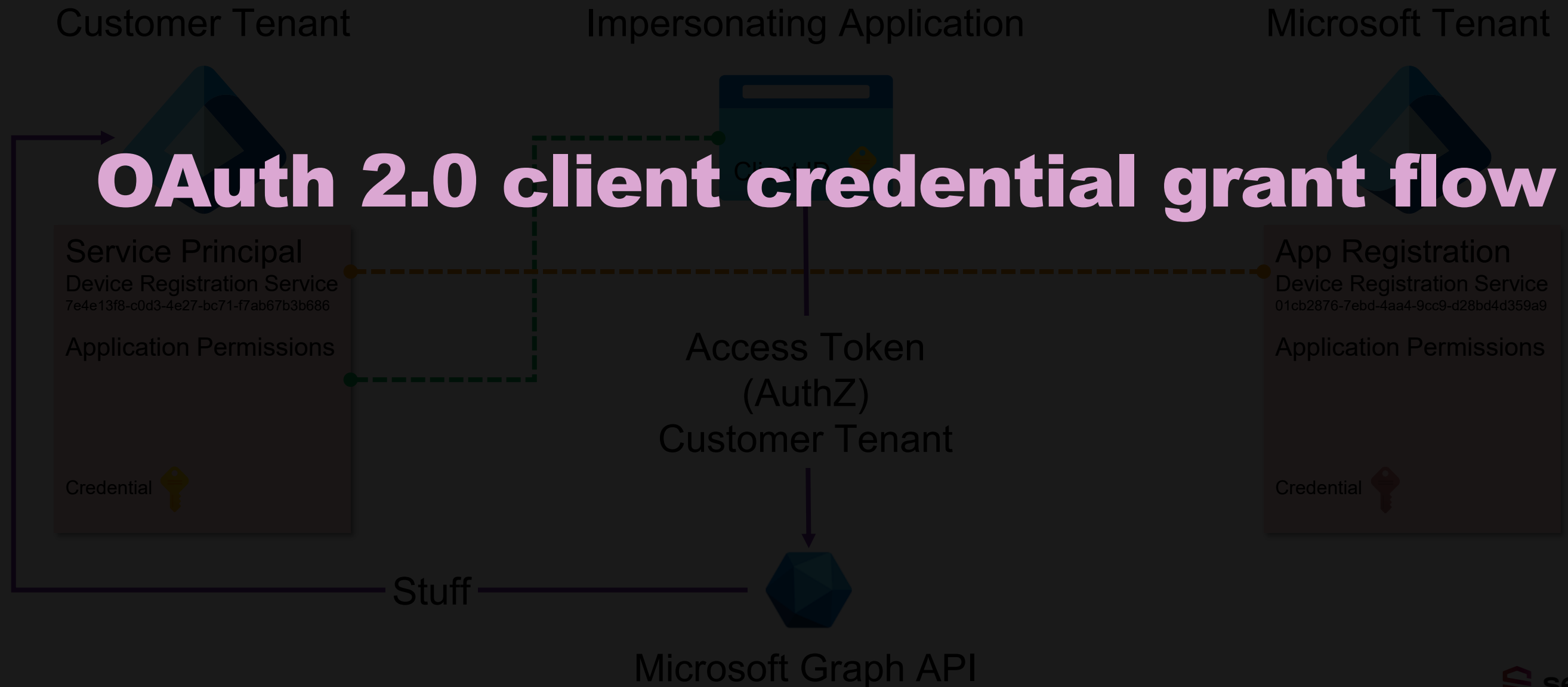
Microsoft Tenant

Act as Microsoft service principals for multi-tenant applications

“Borrowing their identity”

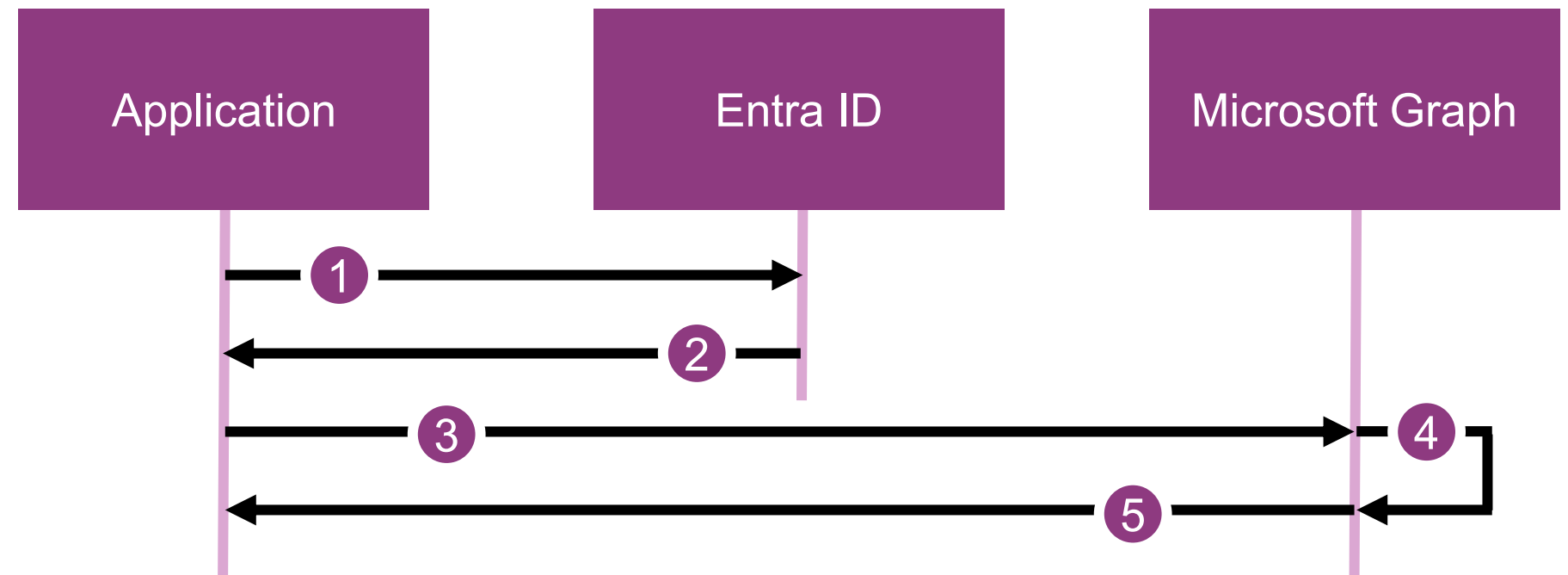


Impersonating Microsoft applications



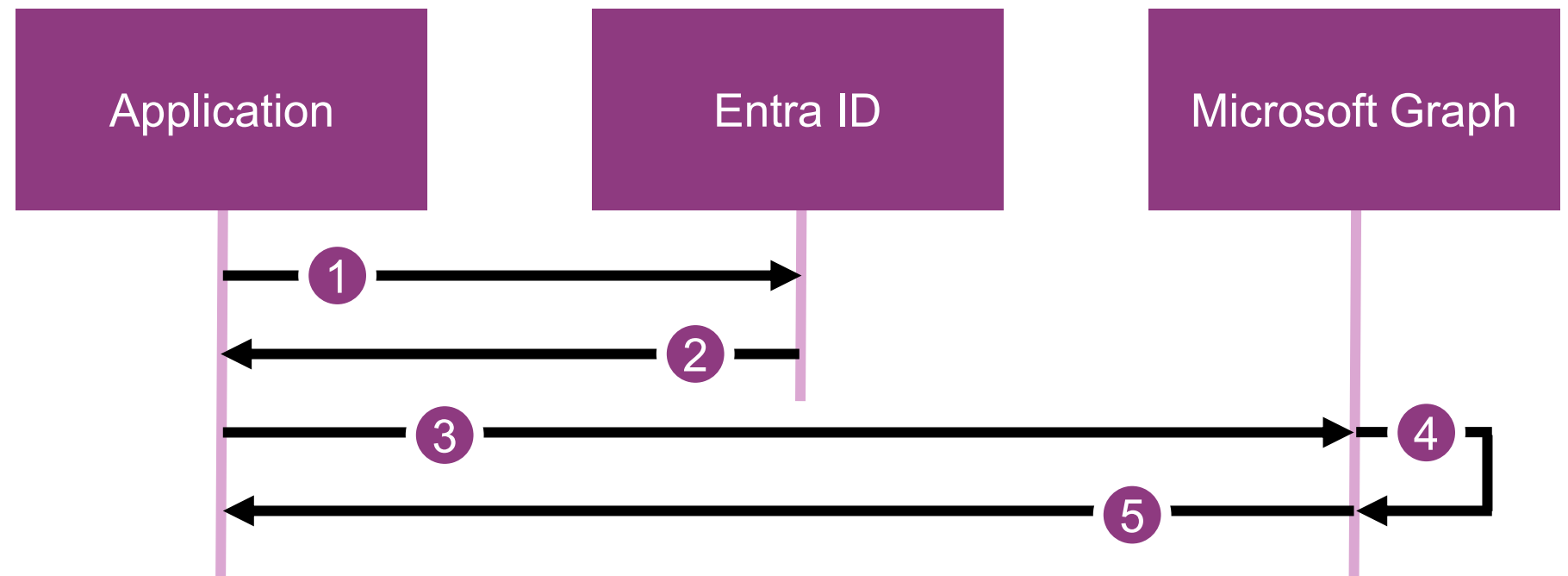
OAuth 2.0 client credential grant flow

1. Application requests an access token from Entra ID with the client ID and credential
2. Entra ID returns an access token
3. Application calls Microsoft Graph with the access token
4. Microsoft Graph validates the access token
5. Microsoft Graph returns the requested data



OAuth 2.0 client credential grant flow

- In a client credential grant flow, the .default scope is the only scope permitted by Microsoft Graph
- .default scope is the application permissions defined in the app registration
- .default scope does not indicate additional permissions provided by other authorization systems





The research

Looking for applications to impersonate

```
$spn = Get-AzureADServicePrincipal -All $true | Where-Object {$_.AppOwnerTenantId -like  
"f8cdef31-a31e-4b4a-93e4-5f571e91255a"}
```

```
$spn | Foreach-Object {  
    $cred = $null  
    $cred = New-AzureADServicePrincipalPasswordCredential -ObjectId $CurrentSPN.ObjectId  
        -EndDate $notafter  
    $output = $_.DisplayName + "," + $_.ObjectId + "," + $_.AppId + "," + $cred.Value  
    $output | Out-File C:\temp\serviceprincipals.csv -Append  
}
```


Looking for applications to impersonate

	A	B	C	D
1	Name	OID	AppID	PW
2	ChatMigrationService1P	006daeab-5acd-481f-a9ba-9bb5913f9b72	3af5adde-460d-4bc1-ada0-fc648af8fefb	FhMiJnIsdCIdUnoGRfUPt7dUPwc1ltYtZmVwMC
3	Microsoft Threat Protection	00aee614-ac22-4ebe-9a13-d77ea09fdd20	8ee8fdad-f234-4243-8f3b-15c294843740	aYF/h4VhzJhP984bu1dXH4LGNVs+VC8bfqTnVl
4	Compute Artifacts Publishing Service	00bc92d9-dff3-4421-ab84-d2158fded358	a8b6bf88-1d1a-4626-b040-9a729ea93c65	V0Vis4ndoAPKIAFBWRYLgXMAgphafM2O78uIV
5	Recommended	00fb2610-2358-47c7-805d-d9bd849aa0df	98c8388a-4e86-424f-a176-d1288462816f	mpNiY4kFxLJZs+0cOqlpZBBgBVaLrV41dG1pkt9
6	asmcontainerimagescanner	0136d09b-bf2a-47f3-9f7a-41652c89d1d4	918d0db8-4a38-4938-93c1-9313bdf0272	G7k5NvxoMhr9NOIfkY+F6VjNRlglpTp7OgUmGk
7	Azure Credential Configuration Endpoint Service	01c690a3-1de3-443e-93c5-95b314d77e17	ea890292-c8c8-4433-b5ea-b09d0668e1a6	CicmT1ZDDVM3OhSxhjdbINqLnVUiUyx5TMWS
8	Power Platform Governance Services - TIRPS	0269af19-8365-4731-95f3-4dada2c31565	2b5e68f0-bdc2-45b0-920a-217d5cbbd505	CEGlvrmsGS/0mhLDPV8hoOwRzrreJvABAIXET2X
9	Azure Compute	028984c9-e708-4641-8fc9-5fae91350a12	579d9c9d-4c83-4efc-8124-7eba65ed3356	ZGM8fLlvjP3zZeKTeTIQH1kDhMlx1pyajCTsEixP
10	CAS API Security RP Dev	02ed60b6-20db-4a05-bf2e-086deb7e8f62	cb250467-fc8f-4c42-8349-9ff9e9a17b02	et7xe5wUI05N0CoZusFqS8b566Fa11oBHhlsqF
11	Microsoft Teams Partner Tenant Administration	03b8d2ac-ea42-4209-9b68-463a712ef09a	0c708d37-30b2-4f22-8168-5d0cba6f37be	snOXTYKhk/AtYnEypqTbaX4xfk2cr4TwUhb2+Mv
12	Azure Storage Insights Resource Provider	04e976b6-0d37-4d25-989c-f32f0f607049	b15f3d14-f6d1-4c0d-93da-d4136c97f006	SQLr/7DQjN4dCd2acrIse5Qkb0LFX3qDbsj0OS
13	IDML Graph Resolver Service and CAD	06a0b864-182f-4dfb-b767-b97b906ba9fa	d88a361a-d488-4271-a13f-a83df7dd99c2	ng/lGBRIFpU8Du8fmiAYskVwUNs6UFuvpqYiHk
14	Diagnostic Services Trusted Storage Access	072bf89d-e915-49a0-95dc-d4bd0a400add	562db366-1b96-45d2-aa4a-f2148cef2240	vrJGDmbCpjePQ848gbP2lZhZM/Vs+4jkwYTack
15	Microsoft Dynamics CRM Learning Path	0752dc69-9422-49b5-ad82-dd2a1029560b	2db8cb1d-fb6c-450b-ab09-49b6ae35186b	SWTVLOMqcT9P3pQ4CKaLM5hfwoKuHAFPOU
16	OfficeClientService	087c54ed-9c68-4d9b-8d4d-44e4bcf64c09	0f698dd4-f011-4d23-a33e-b36416dcb1e6	wsw1OeOQzxiWqAhEqhXsrma+/bwWXWjTvNp
566	Graph Connector Service	fbba13e-e2f3-479b-9b0c-e59e70e9db5b	56c1da01-2129-48f7-9355-af6d59d42766	jQCPM3EIWJwAM+CbmqcwtdM3MF0ovZmHa6
567	Export to data lake	fc28cd59-096a-4a9f-bce6-2c78f9fdd232	7f15f9d9-cad0-44f1-bbba-d36650e07765	QCV4qQ6SxJIKYxnhjM+z6MN//pbpt4uN9EP0Sg
568	Networking-MNC	fc42d9fe-e142-4ac5-9b87-8d90c173b021	6d057c82-a784-47ae-8d12-ca7b38cf06b4	38E1dpj+XlxnlaGyt/+TwomseYpkxJro65+8wsi6c
569	Cloud Infrastructure Entitlement Management	fc897223-f34c-443b-9cd6-b557ce5c3dc9	b46c3ac5-9da6-418f-a849-0a07a10b3c6c	U21e5uVKrlkk7DRxnXMq7AVTJNwmYbTlfY//ED
570	Azure Guest Container Update Manager	fe3507b5-a34c-4c9b-8d32-a8fc1a6190b4	c8f5141d-83e0-4e9a-84d0-bb6677e26f64	ZxDVULTnXG+zg55i60yAYBKqYMLc/g1nHrQszb
571	Azure AD Notification	fea4cfba-323d-4ab2-b039-1a41348c8c2a	fc03f97a-9db0-4627-a216-ec98ce54e018	HJNH3gepnUMsHCUNa7cRwpWg4SGbw/Cw7
572	Azure Bastion	fedefbbf-3cf4-449f-8bc4-97ff8f6bf184	79d7fb34-4bef-4417-8184-ff713af7a679	rxEqS+xzRiqkdP8iixCeAymMvJYzIukDbtLDDZRr
573	Customer Experience Platform CDPA Provisioning TIP	ff5a6c80-78b9-49c2-9e8f-3fd21f3a13d8	f5223e1a-4d50-4fda-9049-55d819fbb03e	8zwGnq5qVMkiBkFrMBO88uy6GReMqhx+FHTZ
574	Azure Cost Management XCloud	ffdad0a0-a2ac-47e5-b26e-757b835beac2	3184af01-7a88-49e0-8b55-8ecdce0aa950	2sr0paXs1v4/aZJy/C5jIH5orm/WGDHYQE6eP0

Looking for applications to impersonate

```
$spn | ForEach-Object {  
    $cred = New-Object -TypeName System.Management.Automation.PSCredential -ArgumentList  
        $_.AppId,(ConvertTo-SecureString -AsPlainText $_.PW -Force)  
    Connect-MgGraph -TenantID 11ae06df-xxxx-4b9e-bf66-2a91f4955339  
        -ClientSecretCredential $cred  
    Get-MgContext | Out-File C:\temp\ccgfauthworks.txt -Append  
    Disconnect-MgGraph -ErrorAction SilentlyContinue  
}
```

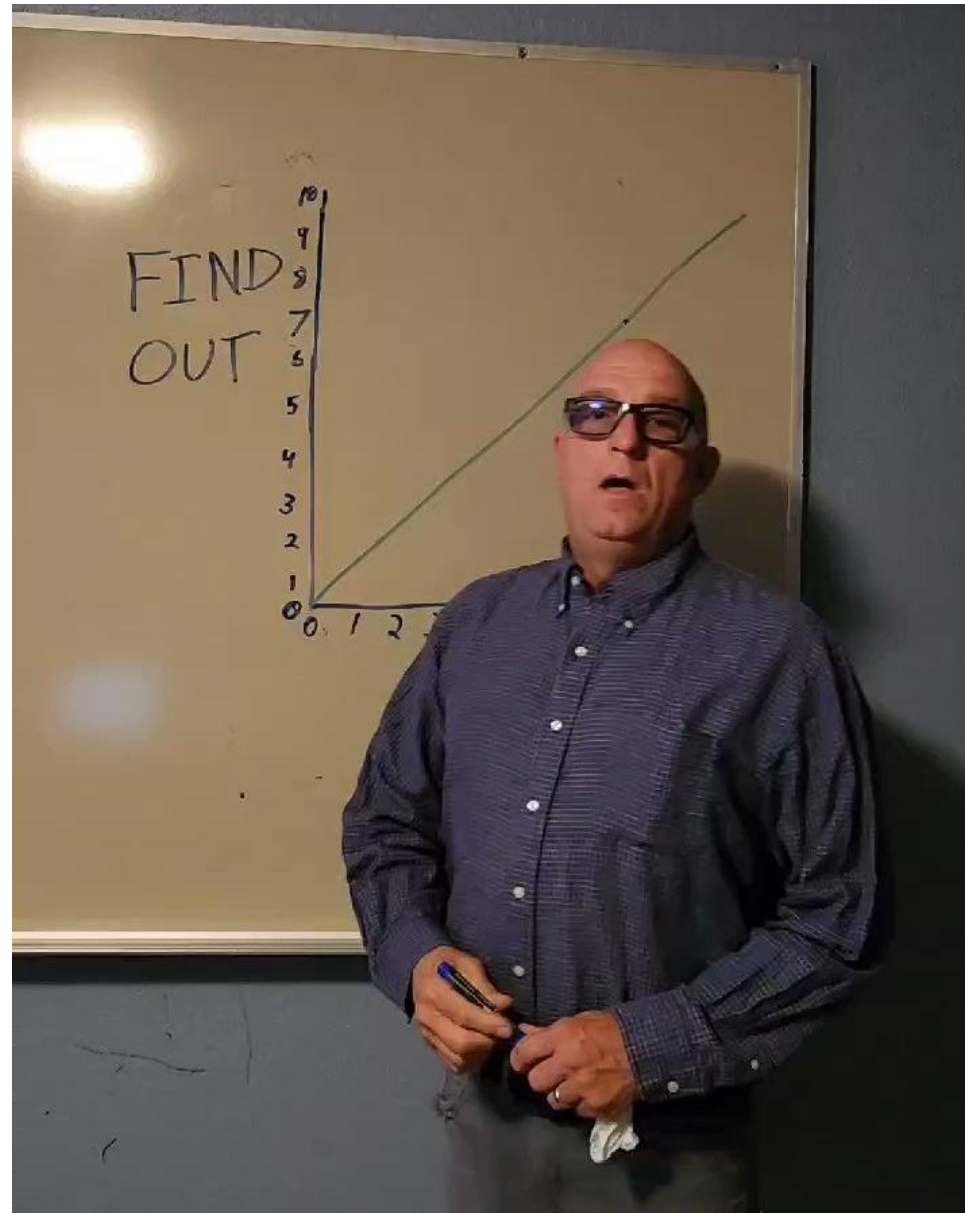

Applications supporting OAuth 2.0 CCGF

- Office 365 Exchange Online
- Office 365 SharePoint Online
- Dataverse
- Viva Engage (Yammer)
- Microsoft Rights Management Services
- Azure Multi-Factor Auth Client
- Skype for Business Online
- AADPasswordProtectionProxy
- Device Registration Service

Looking for the “write” scopes

- Office 365 Exchange Online – [Group.ReadWrite.All](#), [Domain.ReadWrite.All](#)
- Office 365 SharePoint Online – [Application.ReadWrite.OwnedBy](#)
- Dataverse – [OnlineMeetings.ReadWrite.All](#)
- Viva Engage (Yammer) – [Group.Create](#), [Files.ReadWrite.All](#)
- Microsoft Rights Management Services – [No write scopes](#)
- Azure Multi-Factor Auth Client – [No scopes](#)
- Skype for Business Online – [No scopes](#)
- AADPasswordProtectionProxy – [No scopes](#)
- Device Registration Service – [No scopes](#)

Let's try privileged things anyway



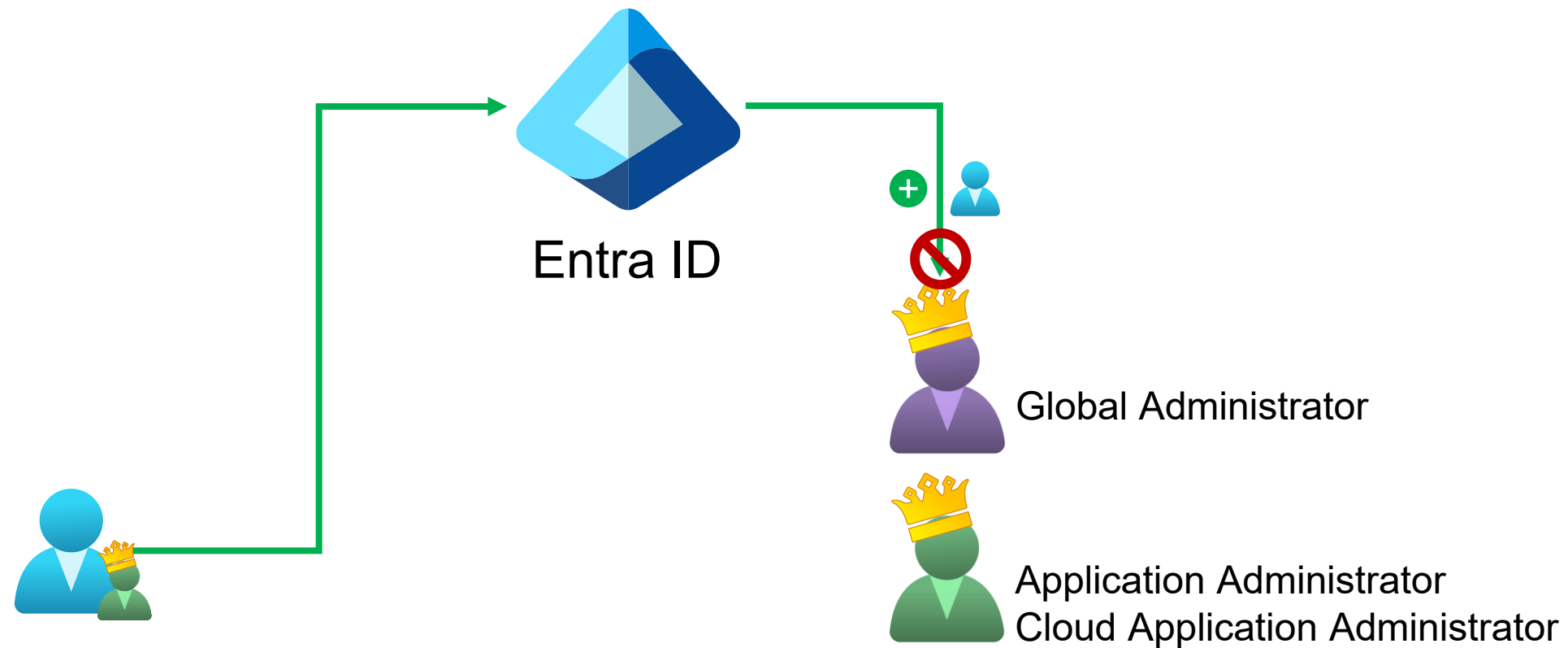
The tests

- Disable a regular / privileged user
- Change a users / privileged users password
- Manage role assignments
- Create a user
- Delete a user / privileged user
- Permanently delete a privileged user
- Create a group eligible for role assignment
- Create an Administrative Unit
- Manage role assigned group membership

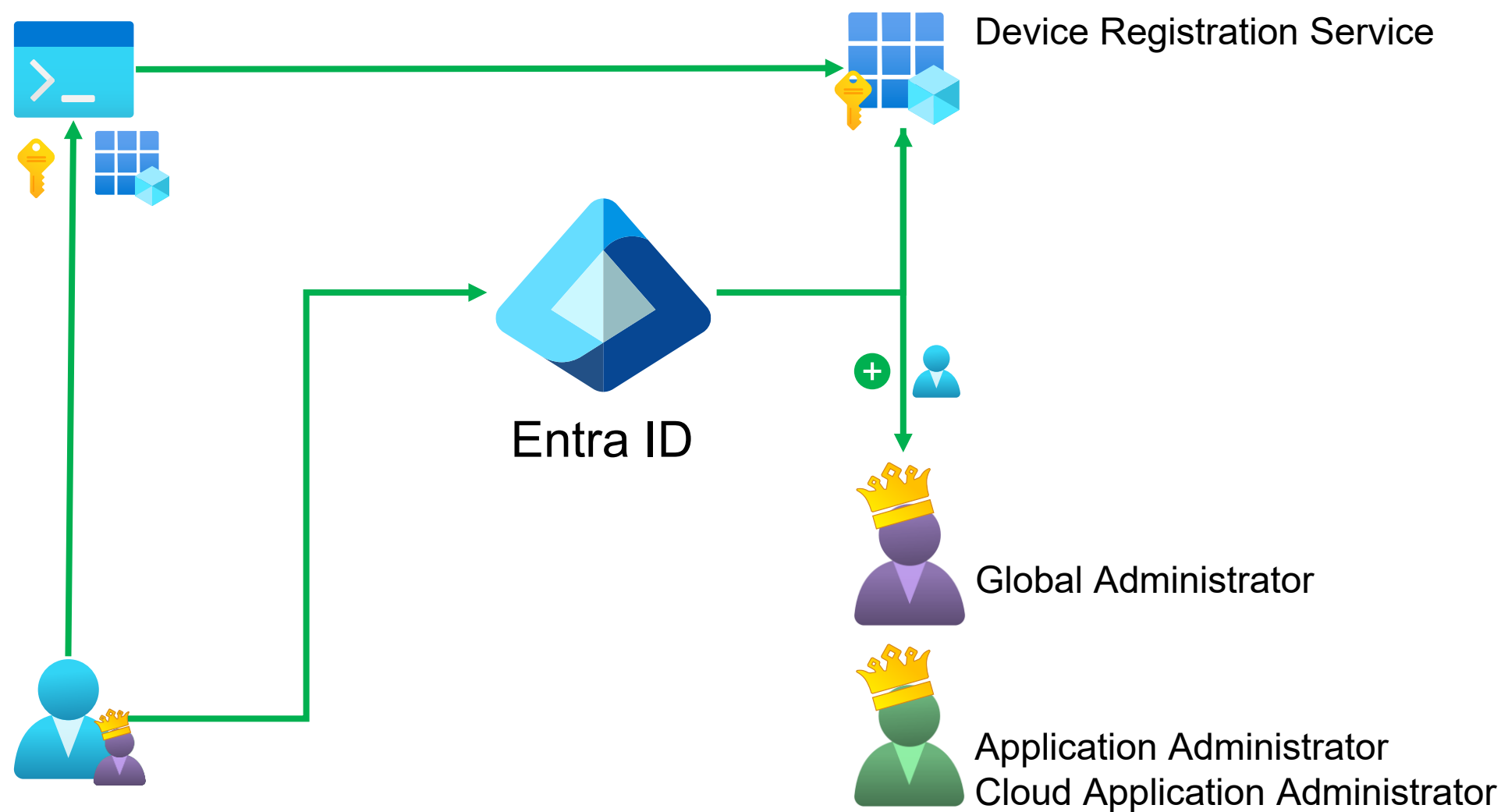


The findings

Application Administrator role



Privilege elevation to Global Administrator

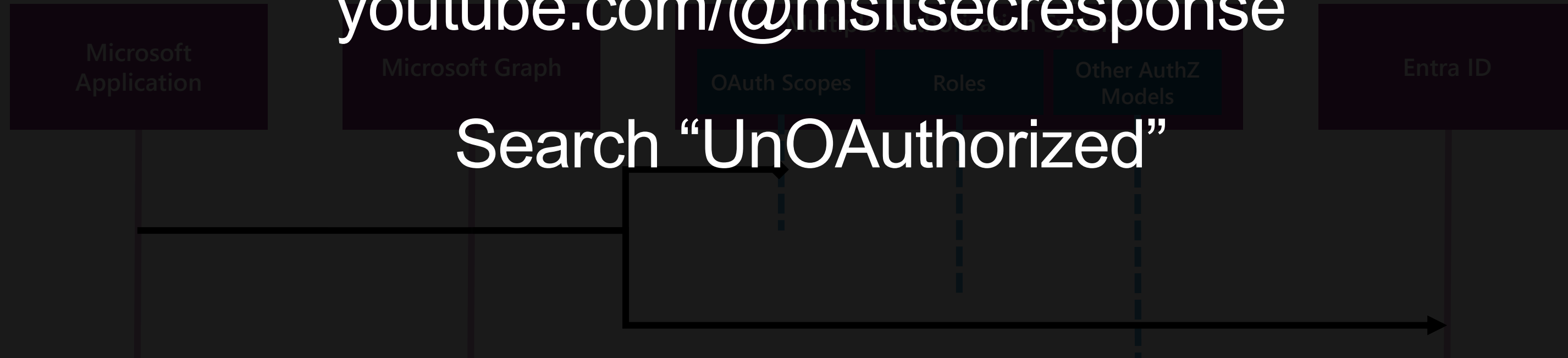


The findings

- Device Registration Service
Modify privileged role assignment
- Viva Engage (Yammer)
Delete and permanently delete privileged users
- Microsoft Rights Management Services
Create users

Why did this work?¹

[youtube.com/@msftsecresponse](https://www.youtube.com/@msftsecresponse)



¹Abstracted a bit



But wait... there's more



The findings

- Device Registration Service
Modify privileged role membership
- Viva Engage (Yammer)
Delete and permanently delete privileged users
- Microsoft Rights Management Services
Create users
- Office 365 Exchange Online
Disable privileged users
- Office 365 SharePoint Online
Disable privileged users



Microsoft response

The findings

- Device Registration Service
MSRC – Important severity, elevation of privilege, resolved
- Viva Engage (Yammer)
MSRC – Medium severity, resolved
- Microsoft Rights Management Services
MSRC – Low severity, resolved
- **Office 365 Exchange Online**
MSRC – Important severity, elevation of privilege, resolved
- **Office 365 SharePoint Online**
MSRC – Important severity, improper access control, resolved

Timeline of the case

Nov 21st 2023
MSRC closes case

Jan 18th 2024
MSRC acknowledges

Mar 17th 2024
Rights Management



Microsoft Security Response Center <secure@microsoft.com>

To:  Eric Woodruff; Microsoft Security Response Center <secure@microsoft.com>



Reply



Reply all



Forward



Tue 2023-11-21 3:26 PM

 You replied on Tue 2023-11-21 3:57 PM

Hi Eric -

Thank you again for submitting this issue to Microsoft. After careful investigation, this case has been assessed and does not meet MSRCs bar for immediate servicing. However, we have shared the report with the team responsible for maintaining the product or service. They will take appropriate action as needed to help keep customers protected. Here are also some details around [Exchange Server hybrid deployments](#) | [Microsoft Learn](#)

As no further action is required by the MSRC, I am closing this case. Please know that there will be no further correspondence from Microsoft regarding this submission.

We appreciate your efforts and thank you for giving us the opportunity to improve our products and protect our customers!

Jan 23rd 2024
MSRC marks case as low severity

Apr 3rd 2024
Rebuttal provided to MSRC

Jun 3rd 2024
Draft of disclosure provided to MSRC

Jan 11th 2024
New case opened with MSRC

Mar 4th 2024
Device Registration Service resolved

Nov 1st 2023
Case opened with MSRC

Timeline of the case

Nov 21st 2023

MSRC closes case

Jan 18th 2024

MSRC acknowledges case

Mar 17th 2024

Rights Management Services resolved

Feb 6th 2024

Rebuttal provided to MSRC

Apr 19th 2024

Viva Engage resolved

Aug 7th 2024

Public disclosure
3 of 5 findings

Feb 14th 2025

Office 365 SharePoint
Online resolved

Working with
MSRC on
disclosure

Jan 29th 2024

MSRC marks case
as low severity

Apr 9th 2024

Rebuttal provided to
MSRC

Jun 5th 2024

Draft of disclosure
provided to MSRC

Jan 11th 2024

New case opened
with MSRC

Mar 4th 2024

Device Registration
Service resolved

Aug 15th 2024

Office 365 Exchange
Online resolved

Nov 1st 2023

Case opened with
MSRC

Applications supporting OAuth 2.0 CCGF

- Office 365 Exchange Online
- Office 365 SharePoint Online
- Dataverse
- Viva Engage (Yammer)
- Microsoft Rights Management Services
- Azure Multi-Factor Auth Client
- Skype for Business Online
- AADPasswordProtectionProxy
- Device Registration Service



Why EXO and SPO are different

Why EXO and SPO are different

- These are hybrid services
- Need a way to connect to on-prem systems


```
PowerShell
Windows PowerShell

PS C:\temp> $cred = New-Object -TypeName System.Management.Automation.PSCredential -ArgumentList "00000002-0000-0ff1-ce00-000000000000", $SPNPW
PS C:\temp> Connect-MGGraph -TenantID 11ae06df-10e8-4b9e-bf66-2a91f4955339 -ClientSecretCredential $cred
Connect-MgGraph: ClientSecretCredential authentication failed: AADSTS7002104: Symmetric secrets may not be set on Service Principals to authenticate this application. Trace ID: 09f01df3-1b38-40bb-86aa-f2efdda3f700 Correlation ID: 7614b86b-3ec0-457b-8318-aa3ff6ec9795 Timestamp: 2025-06-09 22:16:14Z
PS C:\temp>
```

EXO and SPO Changes

Cannot auth with secrets for service principals

```
PowerShell x Windows PowerShell x + v
PS C:\temp> Connect-AzureAD
WARNING: Install the latest PowerShell module, the Microsoft Graph PowerShell SDK, for new features and improvements!
https://aka.ms/graphPSmigration

Account Environment TenantId TenantDomain AccountType
-----
alex.wilber@fabrikam.cloud AzureCloud 11ae06df-10e8-4b9e-bf66-2a91f4955339 fabrikam.cloud User

PS C:\temp> $currentDate = Get-Date
PS C:\temp> $endDate = $currentDate.AddYears(1)
PS C:\temp> New-AzureADServicePrincipalKeyCredential -ObjectId 69fc105c-c6e4-4552-bce9-51416deb9b7f -CustomKeyIdentifier
"Test123" -StartDate $currentDate -EndDate $endDate -Type AsymmetricX509Cert -Usage Verify -Value $keyValue
New-AzureADServicePrincipalKeyCredential : Error occurred while executing SetServicePrincipal
Code: Authorization_RequestDenied
Message: Insufficient privileges to complete the operation.
RequestId: 2ae7226a-d11d-48dc-bd3d-34f99f9251b8
DateTimeStamp: Mon, 09 Jun 2025 22:18:57 GMT
HttpStatusCode: Forbidden
HttpStatusCodeDescription: Forbidden
HttpResponseStatus: Completed
At line:1 char:1
+ New-AzureADServicePrincipalKeyCredential -ObjectId 69fc105c-c6e4-4552 ...
+ ~~~~~
+ CategoryInfo          : NotSpecified: (:) [New-AzureADServicePrincipalKeyCredential], ApiException
+ FullyQualifiedErrorId : Microsoft.Open.AzureAD16.Client.ApiException,Microsoft.Open.AzureAD.Graph.PowerShell.Cus
tom.NewAzureADServicePrincipalKeyCredential
```

EXO and SPO Changes

Only Global Admins can assign credentials


```
PowerShell x Windows PowerShell x + v
339 -CertificateThumbprint $thumb
Welcome to Microsoft Graph!

Connected via apponly access using 00000002-0000-0ff1-ce00-000000000000
Readme: https://aka.ms/graph/sdk/powershell
SDK Docs: https://aka.ms/graph/sdk/powershell/docs
API Docs: https://aka.ms/graph/docs

NOTE: You can use the -NoWelcome parameter to suppress this message.

PS C:\temp> get-mgcontext

ClientId           : 00000002-0000-0ff1-ce00-000000000000
TenantId           : 11ae06df-10e8-4b9e-bf66-2a91f4955339
Scopes              : {Directory.Read.All, Domain.ReadWrite.All, EduRoster.Read.All, Group.ReadWrite.All...}
AuthType           : AppOnly
TokenCredentialType : ClientCertificate
CertificateThumbprint : 473bb50d46995d2b1363ad2d6b6f68b631da0aaf
CertificateSubjectName :
SendCertificateChain : False
Account            :
AppName            : Office 365 Exchange Online
ContextScope       : Process
Certificate         :
PSHostVersion      : 7.5.1
ManagedIdentityId  :
ClientSecret        :
Environment         : Global
```

EXO and SPO Changes

Scopes appear to be reduced/changed

```
PowerShell
Windows PowerShell

Account      :
AppName      : Office 365 Exchange Online
ContextScope : Process
Certificate   :
PSHostVersion : 7.5.1
ManagedIdentityId :
ClientSecret  :
Environment   : Global

PS C:\temp> Update-MGUser -UserId pradeep.gupta@fabrikam.cloud -AccountEnabled:$false
Update-MgUser_UpdateExpanded: Insufficient privileges to complete the operation.

Status: 403 (Forbidden)
ErrorCode: Authorization_RequestDenied
Date: 2025-06-09T22:23:49

Headers:
Cache-Control      : no-cache
Vary                : Accept-Encoding
Strict-Transport-Security : max-age=31536000
request-id         : 15f90236-7bd3-42a5-a884-84dbbabc4f61
client-request-id   : 7862766b-8a91-462a-be2f-6cb8ed5eb626
x-ms-ags-diagnostic : {"ServerInfo":{"DataCenter":"East US","Slice":"E","Ring":"5","ScaleUnit":"006","RoleInst
ance":"BL6PEPF0001B99D"}}
x-ms-resource-unit  : 1
Date               : Mon, 09 Jun 2025 22:23:48 GMT
```

EXO and SPO Changes

Scopes appear to be reduced/changed



Defense

```
PowerShell
Windows PowerShell

PS C:\temp> (Get-MgServicePrincipal -Filter "AppId eq '00000002-0000-0ff1-ce00-000000000000').KeyCredentials

CustomKeyIdentifier  DisplayName  EndDateTime  Key KeyId  StartDateTime
-----
{84, 101, 115, 116...} CN=com.foo.bar 6/9/2026 9:54:38 PM 85a3130f-2576-4dca-beca-dcc42bb924ef 6/9/2025 9:54:38 PM
{84, 101, 115, 116...} CN=com.foo.bar 8/23/2025 1:50:51 PM b2978105-5642-4ab1-9ec8-f689c8dd7daa 8/23/2024 1:50:51 PM
{84, 101, 115, 116...} CN=com.foo.bar 6/13/2025 8:11:52 PM 88e6d155-0de6-4db7-9be9-754c91d33708 6/13/2024 8:11:52 PM
{84, 101, 115, 116...} CN=com.foo.bar 6/13/2025 8:11:52 PM b4633b09-5860-485f-8c85-74d5757f7fdd 6/13/2024 8:11:52 PM

PS C:\temp> (Get-MgServicePrincipal -Filter "AppId eq '00000002-0000-0ff1-ce00-000000000000').PasswordCredentials

CustomKeyIdentifier  DisplayName  EndDateTime  Hint KeyId  SecretText  StartDateTim
e
-----
Pass test 6/9/2027 9:00:37 PM IHD ddd36098-8900-4c2b-8d11-640fadb2df3b 6/9/2025 9:...
10/10/2024 3:04:32 AM 008 209c0ebc-61f6-41f0-a973-ce0ec83f7fff 4/10/2024 3...
4/10/2025 3:04:01 AM gqw 1ab051e9-fd7f-437c-b165-9b971e971dcb 4/10/2024 3...
5/1/2024 7:24:16 PM ZOj f2ce226c-07cb-4b2d-904b-69b278f5be5f 11/1/2023 7...
4/30/2024 9:58:41 PM MU7 4e0d9b74-cb2c-4556-857d-fe6bfbffcd87 10/31/2023 ...

PS C:\temp> |
```

Hunting for credentials

Creds will be expected in hybrid environments



EXO and SPO Client IDs

Client IDs are globally unique

Office 365 Exchange Online

00000002-0000-0ff1-ce00-000000000000

Office 365 SharePoint Online

00000003-0000-0ff1-ce00-000000000000



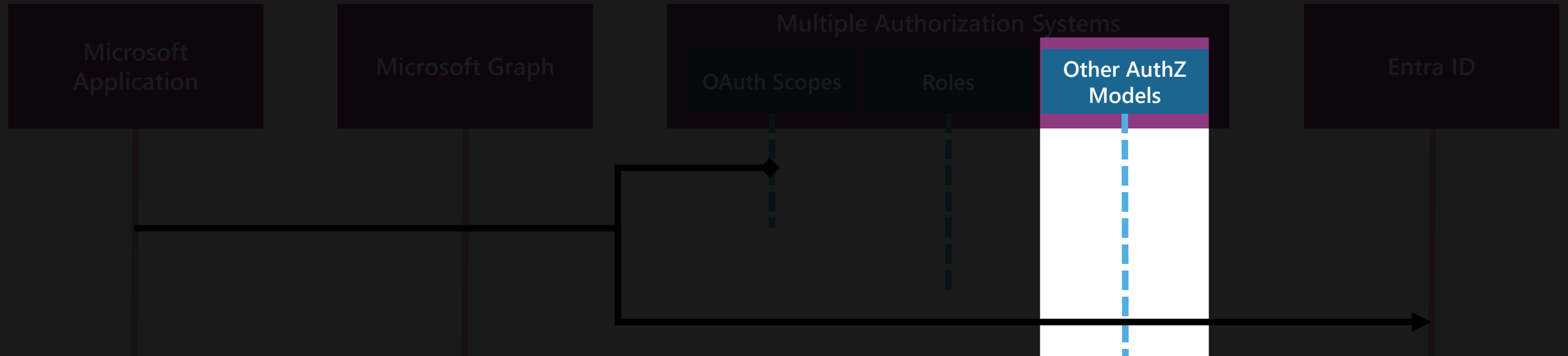
Impact on third party applications



Can this specific finding impact non-Microsoft applications?

No

Why did this work?¹



¹Abstracted a bit



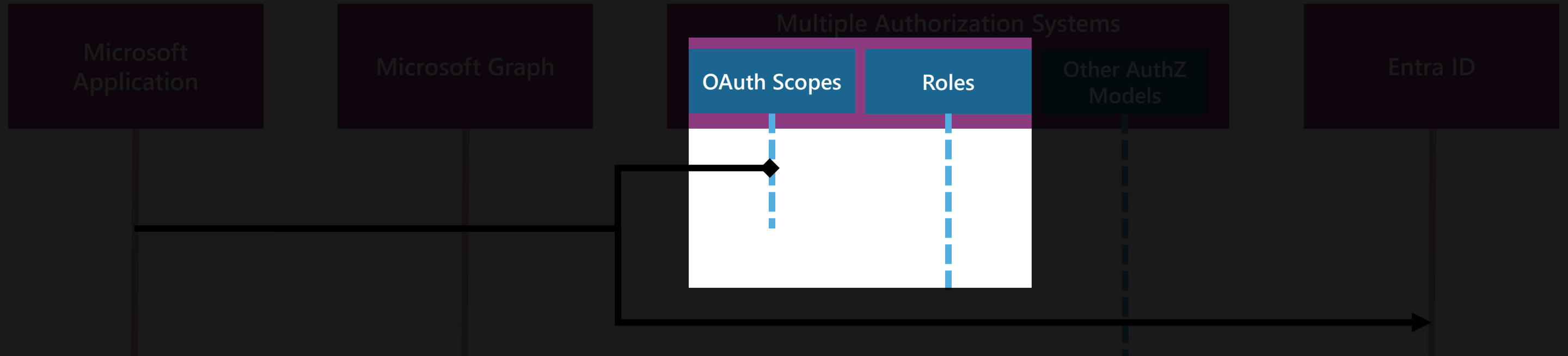
Can this specific finding impact non-Microsoft applications?

No

Can organizations create scenarios that mimic this finding?

Yes

Why did this work?¹



¹Abstracted a bit

Risky applications permissions

RoleManagement.ReadWrite.Directory

AppRoleAssignment.ReadWrite.All

RoleManagement.ReadWrite.Directory

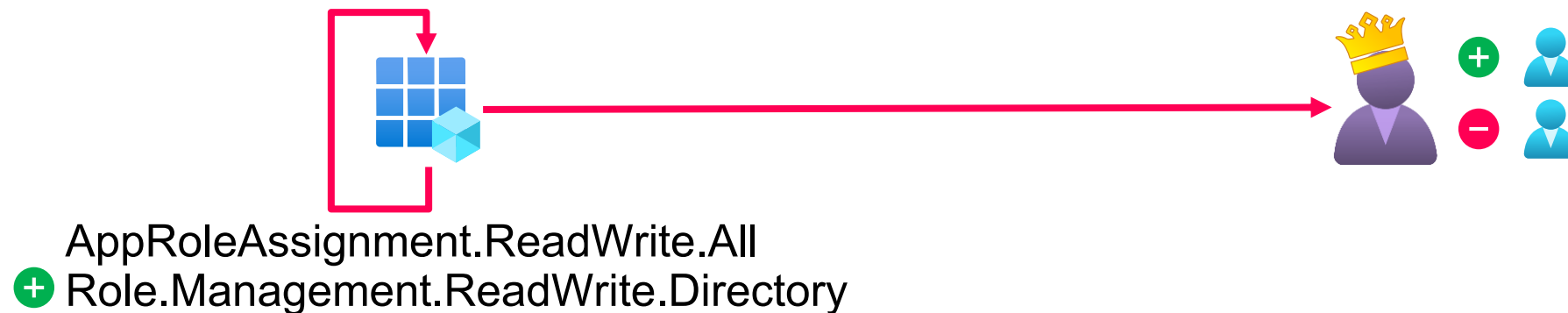
Allows the app to read and manage the role-based access control (RBAC) settings for your company's directory, without a signed-in user. This includes instantiating directory roles and managing directory role membership, and reading directory role templates, directory roles and memberships.



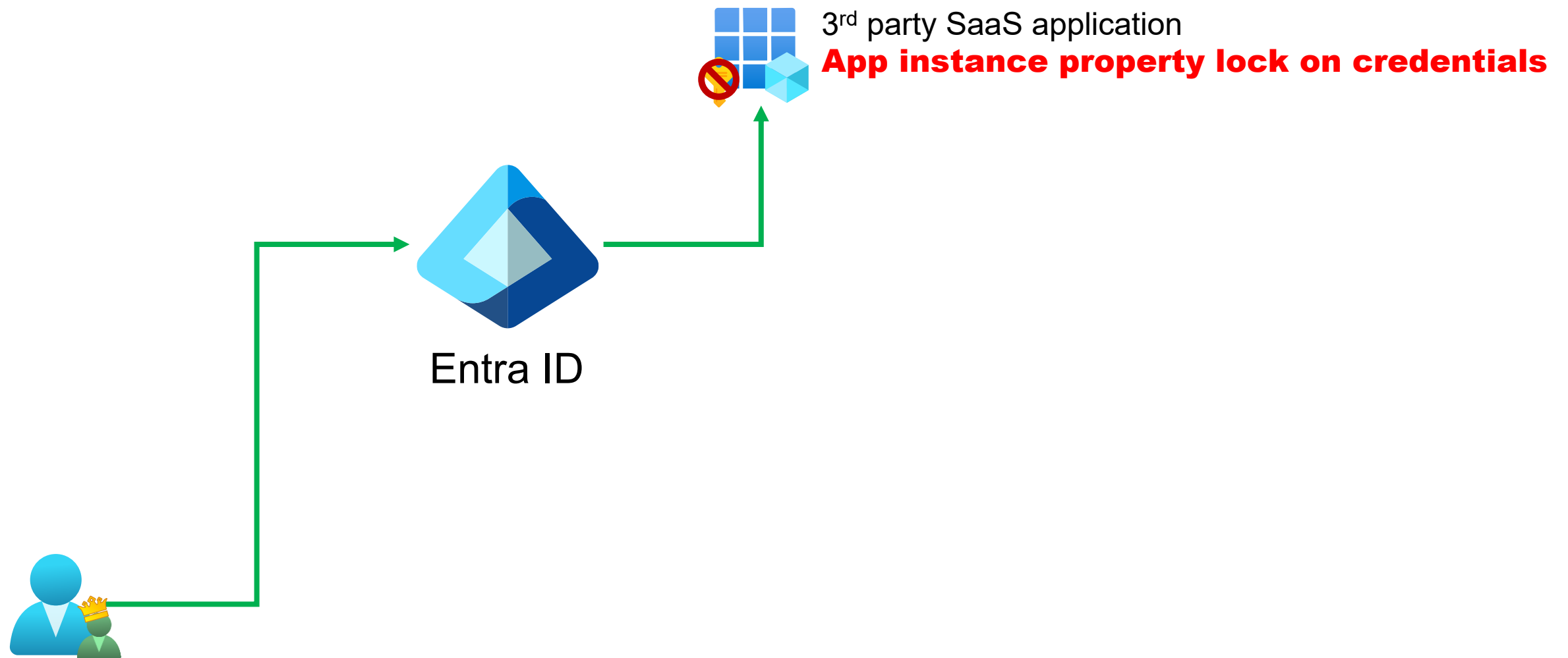
Role.Management.ReadWrite.Directory

AppRoleAssignment.ReadWrite.All

Allows the app to manage permission grants for application permissions to any API (including Microsoft Graph) and application assignments for any app, without a signed-in user.



App instance property lock



App instance property lock

Privileged Application

Prevent malicious attacks by blocking the modification of sensitive properties of this application.

☒ Enable property lock

Locked properties

4 selected

- ☒ All properties
- ☒ Credentials used for verification
- ☒ Credentials used for signing tokens
- ☒ Token Encryption KeyId

POST

v1.0

https://graph.microsoft.com/v1.0/servicePrincipals/73f55901-7dfd-4cbc-a329-188c7...

Run query

No resource was found matching this query

Request body

Request headers

Modify permissions

Access token

Bad Request - 400 - 332 ms

Response preview

Response headers

Code snippets

Toolkit component

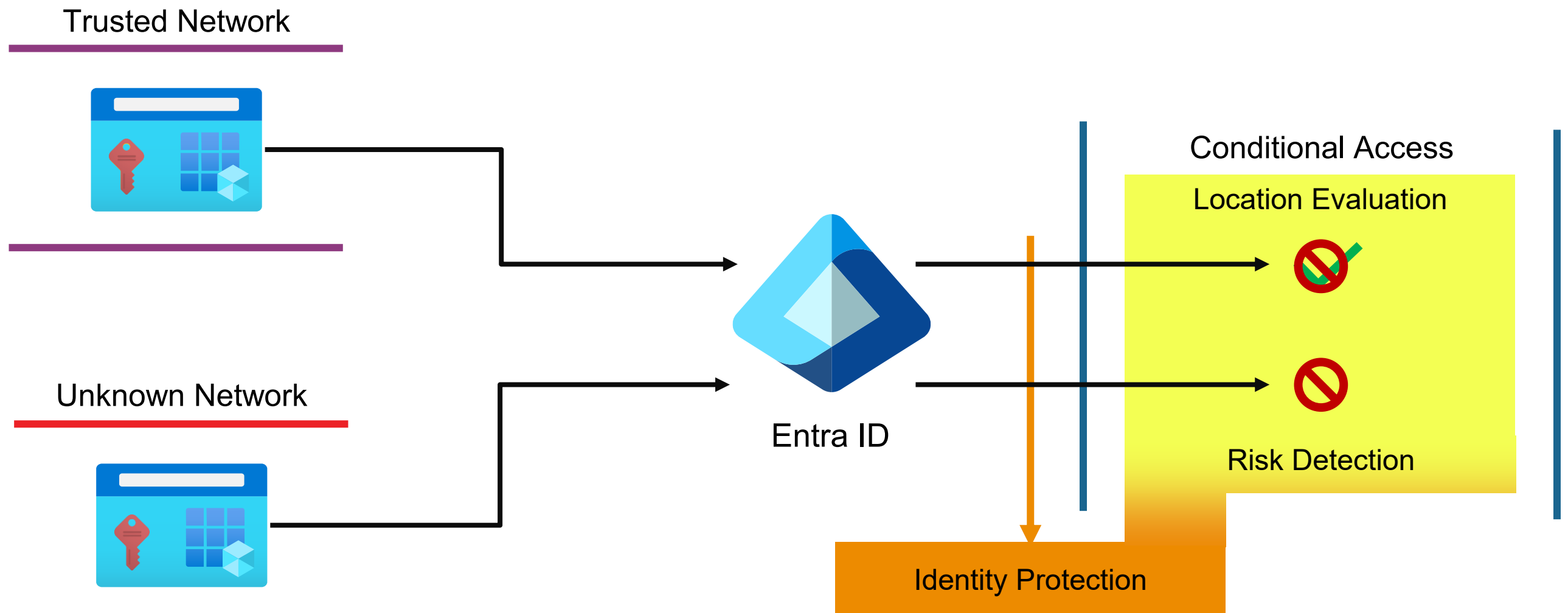
Adaptive cards

Expand

```
{
  "error": {
    "code": "CannotUpdateLockedServicePrincipalProperty",
    "message": "Property passwordCredentials is invalid.",
    "details": [
      {
        "code": "GenericError",
        "message": "Property passwordCredentials is invalid.",
        "target": "passwordCredentials",
        "blockedWord": "",
        "prefix": ""
      }
    ]
  }
}
```

App instance property lock

Workload Identities Premium





Recap



Entra Authorization Model

Check your tenant for UnOAuthorized – it's easy
(but not a guarantee)

Third party and business privileged apps are not
impacted

Third party and business privileged apps are
vulnerable to misconfiguration

Full details on UnOAuthorized

sl.entra.ms/unoauthorized

Updated soon with this talk